Printout Buddy
Schema V2 architecture

Customer + shop-owner marketplace: analysis, decisions, schema, API contracts, state machines, security, migration, rollout, and implementation record.

Generated 2026-10-28 from docs/schema-v2/. OpenAPI: docs/schema-v2/openapi-schema-v2.yaml.

01 – PDF-to-code gap analysis

Source of the target: `printout_buddy_schema.pdf` (23 pages, "Database Schema, API and Business Logic"). Source of the as-is: `origin/main` at `080c6bd` (`apps/api/prisma/schema.prisma`, 113 registered routes, see `docs/architecture/api-inventory.md` on PR #44).

Status vocabulary: EXACT_MATCH, PARTIALLY_IMPLEMENTED, MISSING, CONFLICTS_WITH_CURRENT_SYSTEM (C), LEGACY_FEATURE_TO_PRESERVE (L), UNSPECIFIED_OR_AMBIGUOUS (U).

Headline finding. The PDF describes a *customer marketplace* (accounts, discovery, geo search, ordering by authenticated customers, reviews, UPI tracking, 7-day file retention). The repository is a *shop-side print queue* with guest QR ordering. Only the shop-owner side, Firebase identity, FCM, audit and some pricing/order concepts overlap. There is **no customer account, no geo data, no PostGIS, no review, no payment tracking and no customer notification** in code today.

1. Tech stack (PDF p1)

Item	PDF	Current	Status
Login	Firebase Auth, ID token on every API call	Firebase used only for Google/phone exchange at `POST /auth` and web equivalents; API uses its own access + rotating refresh tokens (`routes/auth-mobile.ts`, `auth-refresh.ts`); ID token is rejected by all other routes	C (by design, see 06)
Push	FCM	`FcmRegistration` (token AES-GCM encrypted), `notifications/fcm.ts`	PARTIALLY_IMPLEMENTED (shop owners only)
File storage	Cloudflare R2 private	`apps/api/src/storage/*` driver abstraction (local + S3-compatible)	PARTIALLY_IMPLEMENTED (confirm production driver)
Database	PostgreSQL + PostGIS	PostgreSQL; no PostGIS (no migration, no code)	MISSING
Backend	Node/TS	Fastify/TS	EXACT_MATCH
Signed URLs 2-5 min	Download URL 2-5 min	HMAC signed URL for local driver; shop document access via authenticated route	PARTIALLY_IMPLEMENTED

2. Entities (11 PDF tables)

Current schema: 32 Prisma models and 14 enums (`grep -c '^model ' schema.prisma`). Most overlap is with the shop-owner side.

#	PDF table	Current model	Status	Gap
1	users	`User`	C/PARTIAL	Role is a single enum `SHOP_OWNER|PLATFORM_ADMIN`; no `customer`; no multi-role array; email required+unique, no phone/name split, no `phoneNumber` on User (phone is in `UserPhoneIdentity`), no referral, no address/location, no `isActive` (blocking is via `Shop.status`), `passwordHash` required. Firebase uid lives in identity tables, not `User.firebaseUid`.
2	userFcmTokens	`FcmRegistration`	PARTIAL	Same concept; keyed `(userId, installationId)`, encrypted token + hash (stronger than PDF). Platform values already android/ios/web. No customer use yet.
3	shops	`Shop` + `ShopSettings`	PARTIAL	Missing: ownerId (via `User.shopId` / `Membership`), phone, email, structured address (only `address`, `pincode`), city/state/country, `location` geography, isVerified/verifiedAt/verifiedBy, isOpen (hours engine computes it), isActive (`ShopStatus`), upiId, acceptedPaymentMethods, showQr, qrCodeUrl, profilePhoto, ratingAvg/ratingCount.
4	shopRates	`PricingRule`	C	Per **sheet**, keyed by paperSize x colour x sides. PDF is per **page** x printingType. Not interchangeable (see 02, 04).
5	shopPaperOptions	none (`PricingRule.paperSize` implies sizes)	MISSING	No paperType concept anywhere.
6	shopImages	none	MISSING	
7	orders	`Order` + `Document`	PARTIAL/C	See section 3.
8	orderStatusHistory	`OrderStatusHistory`	PARTIAL	Has from/to/reason/actor user or device. Statuses differ. `changedBy` in PDF is a user id only.
9	reviews	none	MISSING	
10	notifications	`ShopNotification`	PARTIAL	Shop-scoped, outbox-like, seq-ordered, SSE. PDF is per-user (customers too).
11	auditLogs	`AuditLog`	PARTIAL	Has actor/action/target/metadata. PDF's `before` / `after` jsonb would be carried in `metadata`; append-only not enforced (open decision 4 in SCHEMA_ALIGNMENT.md).

3. Enums

PDF enum	PDF values	Current	Status
userRole	customer, shopOwner, admin	`Role`: SHOP_OWNER, PLATFORM_ADMIN	PARTIAL: `CUSTOMER` missing; naming differs (map, do not rename).
printingType	colored, blackWhite	`ColourMode`: bw, colour (+ `PrintSides`)	C: spelling and a missing sides dimension.
orderStatus	pending, accepted, printing, ready, completed, rejected, cancelled	`OrderStatus`: NEW, ACCEPTED, PRINTING, PRINTED, READY, COLLECTED, CANCELLED, EXPIRED	C: no REJECTED (D7 adds it); extra PRINTED/EXPIRED; COLLECTED ~ completed. Cancel is currently shop-side.
paymentMethod	cash, upi	none	MISSING
paymentStatus	unpaid, pendingVerification, paid, refunded	none (`Payment.status` is free text, unused, platform billing)	MISSING

4. Order columns (PDF p5) vs `Order` / `Document`

PDF field	Current	Status
id, createdAt, updatedAt	present (cuid, not uuid)	EXACT_MATCH (id type differs: keep cuid)
orderNumber unique `PB-YYYYMMDD-####`	`orderNumber` unique per shop (`@@unique([shopId, orderNumber])`), per-shop counter, format differs	PARTIAL: global uniqueness is not required by code
customerId	none (guest; `customerDisplayNameOrReference` free text)	MISSING
shopId	present	EXACT_MATCH
ownerId (denormalised)	not needed today (shop-scoped)	MISSING
fileKey/fileName/fileContentType/fileSizeBytes/pages	`Document.objectKey, originalFilename, detectedMimeType, byteSize, pageCount`	PARTIAL (join through `documentId`)
fileDeletedAt	`Document.deletedAt`	PARTIAL
printingType, paperSize, paperType, copies, note	inside `printOptionsSnapshot` JSON (colour, sides, copies, paper size; no paperType, no note)	PARTIAL
pricePerPagePaise, totalPages, totalPaise	`priceSnapshot` JSON (per-sheet), `totalPaise`	C for per-page; totalPaise EXACT_MATCH
paymentMethod/paymentStatus/upiTxnRef	none	MISSING
status	`OrderStatus`	C
rejectReason/cancelReason	`OrderStatusHistory.reason`	PARTIAL
isReviewed, acceptedAt, completedAt	none (derivable from history)	MISSING/derivable
Idempotency-Key header	`clientRequestId` unique per shop	PARTIAL
Server-authoritative price	quote-token + server pricing (`domain/pricing.ts`, `quote-token.ts`)	EXACT_MATCH (concept)

5. API endpoints (PDF p7-19)

Current labels: LIVE = same contract, DIFF = route exists with different contract, NEW = absent. Full mapping in `05-api-contract-mapping.md`.

PDF endpoint	Current	Status
POST /auth/login (Firebase idToken in body)	`POST /auth` (mobile), `/auth/firebase/exchange`, `/auth/google/session`, `/auth/phone/session`, `/auth/login`	DIFF (C: different token model)
GET /me, PATCH /me	`GET/PATCH /users/me`	DIFF
PUT/DELETE /me/fcm-token	`PUT/DELETE /users/me/fcm-token`	DIFF (path, owner only)
GET /shops/nearby	none	MISSING
GET /shops/{id}	`GET /public/shops/:slug` (slug, no auth)	DIFF
GET /shops/{id}/reviews	none	MISSING
POST /uploads/presign	`uploads/initiate` + upload PUT (HMAC token, 15 min)	DIFF
POST /orders, GET /orders, GET /orders/{id}, GET /orders/{id}/file, POST cancel, POST payment	`POST /public/shops/:slug/orders`, `GET /public/orders/:token`	DIFF (guest, tracking-token capability)
POST /reviews	none	MISSING
GET /shops/mine	`GET /shops/me` (single shop)	DIFF

PDF endpoint	Current	Status
PATCH /shops/{id}	`PATCH /shops/me`, `PUT /shop/settings`	DIFF
PUT .../rates	`/shop/pricing-rules` CRUD	DIFF (per sheet)
PUT .../paper-options, POST .../images	none	MISSING
GET /shops/{id}/orders, PATCH .../status	`/shop/orders*` (+ print-now, device order routes)	DIFF (different statuses, no reject)
PATCH .../payment	none	MISSING
POST/GET /admin/shops, PATCH verify/block	`POST/GET/PUT /admin/shops`, `/admin/shops/:id` (status via PUT)	PARTIAL/DIFF

Route methods missing from current code: nearby, reviews x2, presign (as specified), customer orders x6, images, paper-options, payment x2, verify, block = **~20 of 33 PDF operations are NEW**; ~13 have a differing live equivalent; **0 are EXACT_MATCH** (paths, auth and envelopes differ: PDF errors are flat `{code,message,details}`, current is `{error:{code,message,requestId,details}}`; success bodies are un-enveloped in the PDF, enveloped `{data}` here; pagination `{items,page,limit,total}` is not the current shape either).

6. Business rules

Rule	Status
Login claims admin-created owner by phone match	C: current rules forbid auto-link by matching phone/email (explicit, re-authenticated linking only). Do **not** implement.
New user gets `customer`, referral codes	MISSING (referral is an unspecified growth feature; defer)
Nearby: verified, active, ST_DWithin, sort distance then rating, closed listed	MISSING
Order create checks order (closed, rate, paper, payment, file HEAD, key prefix `uploads/{userId}/`, server page count, copies 1-50, idempotency)	PARTIAL: closed (hours engine), rate, document validation, page count (`pdf/`), idempotency exist; paper type, payment, copies cap and user-scoped key prefix do not
Status flow + actors + history + FCM push	PARTIAL/C (see 08)
30-minute pending auto-cancel	U (optional in PDF); current has EXPIRED via worker for unprinted docs
Cash/UPI, UTR uniqueness per shop, refunds admin-only	MISSING
Reviews transactional with rating recompute	MISSING
Verification, block, audit	PARTIAL (`PUT /admin/shops/:id` status, AuditLog)
Rates: replace set in a transaction; need >=1 rate before open	PARTIAL
Admin create: reuse user by phone	C (same linking rule)
File lifecycle: orphan 24h, 7-day post-order delete, 2-5 min signed URL	C/PARTIAL: orphan cleanup 24h (`UNPRINTED_RETENTION_HOURS=24`) matches; **post-print retention is 30 min (`PRINT_RETENTION_MINUTES=30`) vs 7 days** (privacy decision, see 09)
FCM: after commit, delete UNREGISTERED tokens	PARTIAL (`failureCount`, revocation)
Rate limits (login 10/min, presign 50/h)	PARTIAL (login 10/min exists; no presign hourly quota)
UTC storage, IST display	EXACT_MATCH

7. Indexes (PDF p23)

Index	Status
users phone/email/referral/firebaseUid unique	PARTIAL (email unique; uid and phone unique in identity tables)
shops ownerId, GiST location, flags	MISSING
shopRates (shopId, printingType)	C (`PricingRule` unique differs)
orders (shopId,status,createdAt)	EXACT_MATCH
orders customerId/ownerId/upiTxnRef-shopId	MISSING
reviews, userFcmTokens token unique	MISSING / EXACT_MATCH (`tokenHash` unique)

8. Legacy features not in the PDF (LEGACY_FEATURE_TO_PRESERVE)

Guest QR ordering and tracking tokens; quote tokens; `CustomerSession`; owner password, Google and phone sign-in; Admin TOTP 2FA and recovery codes; `PhoneOnboardingGrant`; web cookie+CSRF sessions; mobile refresh rotation; `ShopSettings` hours/timezone/closures/AfterHoursPolicy; `ShopDevice` / `DevicePairingCode` / `DevicePrinter` / `DevicePrintJob` (Android/Windows print path); `PrintAgent` / `Printer` / `PrintJob` (unused additive tables); `Plan` / `Subscription` / `Invoice` / `Payment` (billing, dormant; shops are free); `ShopNotification` + SSE; revenue estimate report; QR poster; History/CSV.

9. Coverage (honest estimate)

Counting the 11 tables, 5 enums and 33 operations as 49 items, a rough hand tally gives: a handful EXACT_MATCH (UTC rule, backend stack, `orders(shopId,status,createdAt)` index, `totalPaise`), about 18 PARTIAL, about 20 MISSING and about 8 CONFLICT. **Roughly 40% of PDF requirements have a usable foundation in code; ~0% of the customer-facing contract is live.** These counts are judgement-based, not mechanically derived.

10. UNSPECIFIED_OR_AMBIGUOUS in the PDF

- Order status/"Windows agent" interplay is not described at all.
- `Shop.isVerified` vs the free self-signup that already produces an immediately ACTIVE shop.
- Whether `ratingAvg` rounds or truncates (`numeric(2,1)`).
- "Pages x copies" for duplex; PDF has no sides.
- `reviews.shopId` and `orders.ownerId` denormalisation when a shop changes owner.
- PDF mixes `shop_*` camelCase table names with the repo's PascalCase Prisma models; no physical rename is needed.
- Referral reward is undefined; whether `customer` and `shopOwner` roles may share one login identity is undefined.
- GET /orders/{id}/file for shop owners vs the existing document access rules.
- PDF API examples show `shp_...` ids, existing ids are cuid.

02 – Architecture decisions

Status vocabulary: **PROPOSED** (suggested by the architecture work), **APPROVED** (historical label, superseded: every row below is now APPROVED), **APPROVED** (owner confirmed), **BLOCKED**, **SUPERSEDED**.

Owner approval recorded 2026-10-28 (one-time authorization in the project conversation): D1-D8, AD-3, AD-6, admin-only manual refunds and the 50 MiB upload limit are APPROVED and FINAL for this implementation. Implementation status is tracked in `IMPLEMENTATION_PROGRESS.md`.

A. Decision register (owner preferences, awaiting confirmation)

#	Topic	Recorded preference	Status	Dependencies and conflicts	Preserved production behaviour
D1	Product scope	Full customer + shop-owner marketplace	APPROVED	Needs customer role, discovery, ordering, reviews, payments and notifications; delivered in phases 1-6 (11). Large: no phase may be skipped or merged into one PR.	Guest QR ordering, owner dashboard and Windows/Android print path keep working.
D2	Pricing	Keep per-sheet calculation, including correct duplex. Customers see clear, server-authoritative quotes	APPROVED	Conflicts with PDF `shopRates` (per page x printingType) and with `PDF orders.pricePerPagePaise/totalPages`. Resolved by: PDF fields are API *projections* only; stored price stays `PricingRule.pricePerSheetPaise` and `Order.priceSnapshot`. Duplex: one sheet = two pages. Quote must come from the existing quote-token path; any client amount is ignored.	`POST /public/shops/:slug/quotes` and order creation unchanged.
D3	Retention	Keep 30 min after print and 24 h for unprinted; no 7-day retention without separate approval	APPROVED	Conflicts with PDF 7-day rule and with `GET /orders/{id}/file` for customers. Consequence: the customer file re-download endpoint is **BLOCKED** (not offered) while 30 minutes stands. Upload cap stays 50 MiB (PDF says 20 MB; separate config decision).	`PRINT_RETENTION_MINUTES=30`, `UNPRINTED_RETENTION_HOURS=24`.
D4	PostGIS	Approved in principle for nearby search, subject to non-production testing and migration review	APPROVED	Production permission to `CREATE EXTENSION postgis` is **unverified** (BLOCKED until checked). Plan: test on a disposable PostGIS-enabled database; migration is its own reviewed PR; nearby search is designed behind a repository interface with a haversine fallback so Phase 2 is not hard-blocked. Docker image used by `docker-compose.yml` / CI must support PostGIS or tests need a separate image.	No production DB change.
D5	Customer email	Permit nullable email if verified identity architecture supports it securely	APPROVED	`User.email` and `passwordHash` are required today. Security condition: a customer is identified by the verified Firebase uid (identity tables), never by email; no linking by email or phone equality; owner and admin accounts keep non-null email and password rules (enforce with a check constraint: nullable email only when role is CUSTOMER). Needs an audit of every `user.email` consumer first.	Owner password/Google/phone sign-in unchanged.
D6	Payments	Customer-to-shop cash/UPI tracking in v1; no automatic processing; no platform subscription billing	APPROVED	New `OrderPayment`; UTR is an unverified claim; only the shop sets `paid`; refund permission undefined (proposed admin-only, **open**). Dormant platform `Payment` / `Invoice` / `Subscription` are untouched. Revenue report remains "estimated order value"; do not relabel it as collected revenue until verified payment data exists.	Shops stay free.
D7	Rejected state	Distinct `REJECTED` via additive, compatibility-tested lifecycle migration	APPROVED	Supersedes the earlier proposal to map reject to CANCELLED (see 08). Risk: Android, web queue, tracking page, analytics, history/CSV, worker cleanup and Windows Agent switch on `OrderStatus`; each must tolerate an unknown value before the enum value is used. Rollout: (1) release clients that tolerate unknown statuses, (2) add enum value, (3) enable shop reject action behind a flag. `ALTER TYPE ADD VALUE` is irreversible.	Existing statuses and the cancel-only live flow unchanged until step 3.
D8	Referrals	Deferred from MVP; future scope	APPROVED	PDF `referralCode`, `referredByUserId` and login referral logic are **not** built; no columns added now.	none

B. Architecture decisions (proposed by this work)

ID	Decision	Status	Rationale
AD-1	PDF = product target; repository = infrastructure authority. No literal adoption of the 11-table schema.	PROPOSED	Existing sessions, devices, 2FA, hours, print path and billing have no PDF equivalent.
AD-2	Keep Prisma names; map PDF names in 04. No table renames.	PROPOSED	Renames break clients and history.
AD-3	Keep the app's access + rotating refresh tokens; Firebase ID tokens are exchanged once at `POST /auth`. The PDF's "ID token on every call" is not adopted.	APPROVED	Revocation, device binding, replay protection and 2FA depend on it (06).
AD-4	Add `CUSTOMER` to `Role` (additive) and `UserRoleGrant` for multi-role; do not change `User.role` to an array.	PROPOSED	`User.role` is a scalar used by guards.

ID	Decision	Status	Rationale
AD-6	No automatic identity linking by email/phone. The PDF's "claim by phone" login step and "reuse user by phone" on admin create are rejected.	APPROVED	Existing security rule.
AD-7	Multi-shop via `Membership`; `User.shopId` stays as default/legacy shop; shop id is a path parameter always checked against membership.	PROPOSED	No caller-controlled tenant switching.
AD-9	`Shop.isVerified` is a separate additive flag from `ShopStatus` and `Subscription`; existing ACTIVE shops are backfilled verified.	PROPOSED	Preserves free signup.
AD-12	Customer ordering reuses existing pricing/validation; guest QR flow untouched; authenticated orders add nullable `customerUserId`.	PROPOSED	
AD-15	New customer routes additive under `/api/v1/customer/...`; multi-shop owner routes under `/api/v1/shops/{shopId}/...`; existing routes never repurposed.	PROPOSED	
AD-16	Envelopes stay `{data}` / `{error:{...}}`; the PDF's flat error shape is not adopted.	PROPOSED	Android parses it.
AD-17	Windows Agent, `DevicePrintJob` and Phase B are untouched until `feature/daksh-phase-b-smart-print-printers` is merged or coordinated.	PROPOSED	

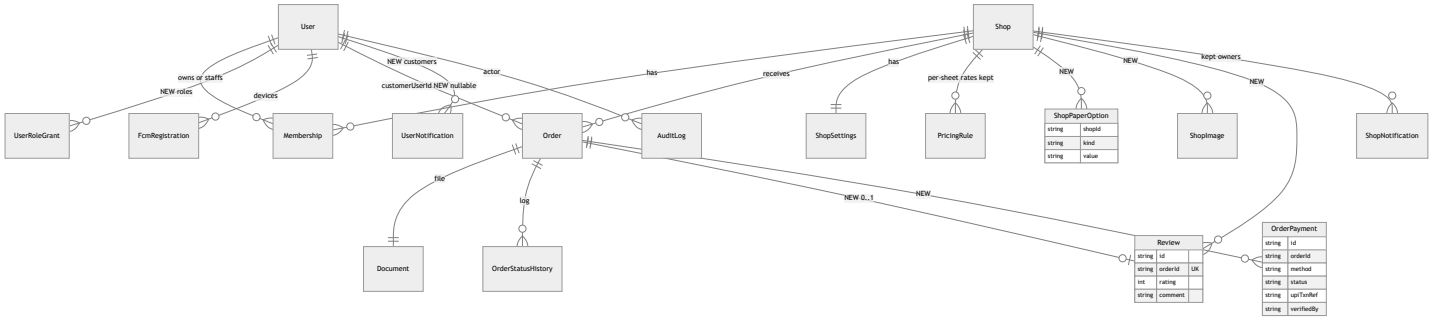
(AD-5, AD-8, AD-10, AD-11, AD-13, AD-14 from the first draft are superseded by D5, D2, D4, D7, D6, D3 respectively.)

C. Unresolved dependencies and conflicts

Item	State
PostGIS on production	APPROVED for implementation; enable only after extension/privilege/backup/performance checks pass; otherwise the application-level fallback ships and PostGIS stays pending
Refund permission	RESOLVED: admin-only manual refund recording, no automatic money movement
Customer app token flow (AD-3)	RESOLVED: existing access/refresh model
Nullable-email consumer audit	required before the Phase 1 migration (in progress)
Phase B overlap (printers/device jobs)	coordinate with Antigravity before Phase 4
Upload cap	RESOLVED: keep 50 MiB
Branch base for PR #45 and the skill PR	see 12 / PR notes: `development` is behind `main`
PDF itself is not committed to the repository	obtain from the owner; references cite it by filename

03 – Target ER diagram (proposed, additive over the current schema)

Entities marked NEW do not exist today. Existing models gain only nullable columns.



New nullable columns: `Shop` (phone, email, city, state, country, latitude, longitude, isVerified, verifiedAt, verifiedBy, upiId, acceptedPaymentMethods, ratingAvg, ratingCount); `Order` (customerUserId, paymentMethod, paymentStatus, note, paperType, acceptedAt, completedAt, isReviewed); `User` (name parts, address, latitude, longitude, isActive, email nullable).

Unchanged infrastructure (see `docs/architecture/full-er-diagram.md` on PR #44): Session, RefreshToken, AdminTwoFactor, AdminRecoveryCode, AdminLoginChallenge, UserGoogleIdentity, UserPhoneIdentity, PhoneOnboardingGrant, ShopDevice, DevicePairingCode, DevicePrinter, DevicePrintJob, PrintAgent, Printer, PrintJob, DeletionReceipt, CustomerSession, Plan, Subscription, Invoice, Payment.

04 – PDF entity → existing entity → change → migration strategy

All migrations are expand-only: nullable columns, new tables, additive enum values. No drops in the first release.

PDF entity	Existing	Change needed	Migration strategy
users	`User` + identity tables	Add `CUSTOMER` to `Role`; allow nullable `email`; add address, latitude, longitude, `isActive`; new `UserRoleGrant(userId, role)`; referral deferred	Nullable columns. Backfill `UserRoleGrant` from `User.role`. `User.role` is not rewritten.
userRole	`Role`	Add `CUSTOMER`. PDF `shopOwner` / `admin` = `SHOP_OWNER` / `PLATFORM_ADMIN` (API alias only)	`ALTER TYPE ... ADD VALUE` (cannot be removed later, harmless)
userFcmTokens	`FcmRegistration`	Customers register with `shopId` null (already nullable). Keep encryption.	none
shops	`Shop` + `ShopSettings`	Add phone, email, address parts, latitude, longitude, `isVerified` / `verifiedAt` / `verifiedBy`, `upiId`, `acceptedPaymentMethods`, rating aggregate. `isActive` = `status == ACTIVE`; `isOpen` = server `evaluateAvailability` and `acceptsOrders`	Backfill `isVerified = true` for existing ACTIVE shops. Shops with null coordinates are excluded from nearby search only.
shopRates	`PricingRule`	Keep. API view maps `(paperSize, colour, sides)`; a per-page figure is projected only for single-sided rules	none
shopPaperOptions	none	New `(shopId, kind, value)` unique table. Seed paperSize from distinct existing `PricingRule.paperSize`. paperType starts empty	Backfill from existing rules. No A3/glossy claim without owner input or printer capability data
shopImages	none	New `(shopId, imageKey, sortOrder)` table, private keys	new table
orders	`Order` + `Document`	Add `customerUserId`, `paymentMethod`, `paymentStatus`, `note`, `paperType`, `acceptedAt`, `completedAt`, `isReviewed`. `ownerId` is derived through shop membership instead of denormalised	Nullable columns; historical rows stay valid as guest orders. `acceptedAt` / `completedAt` backfilled from history
orderNumber	`Order.orderNumber`	Keep per-shop numbering	none
orderStatus	`OrderStatus`	Add `REJECTED`; PDF names map as in 08	additive enum value
orderStatusHistory	same	none (`changedBy` = `actorUserId`)	none
paymentMethod / paymentStatus	none	New enums and `OrderPayment` table	new objects
reviews	none	New `Review`, unique `orderId`, check 1..5	new table
notifications	`ShopNotification`	New `UserNotification` for customers, same outbox and post-commit rules	new table
auditLogs	`AuditLog`	Before/after go in `metadata`; add `shop.verify`, `shop.unverify`, `shop.block`, `shop.unblock` actions	none

Extra existing infrastructure stays unmodified (see 01 section 8).

05 – API contract mapping

Labels: CURRENT_LIVE (exists, same meaning), CURRENT_DIFFERENT_CONTRACT (live route with a different contract from the PDF), NEW_PROPOSED (not in code, not production-ready), DEPRECATED.

Base URL: `https://printoutbuddy.tech/api/v1` (never the PDF placeholder). Envelopes stay `{data}` / `{error:{code,message,requestId,details}}`. Pagination for new list routes is proposed as `{data:{items,page,limit,total}}` with max limit 50, matching the PDF values inside the current envelope.

PDF endpoint	Existing route	Label	Proposed route / adapter	Auth
POST /auth/login	`POST /auth` (mobile), web exchange routes	CURRENT_DIFFERENT_CONTRACT	Keep. Extend `POST /auth` so a verified Google/phone identity with no account can become a **customer** (new `nextStep`), without silent owner linking	none
GET /me	`GET /users/me`	CURRENT_DIFFERENT_CONTRACT	Add customer fields additively	any session
PATCH /me	`PATCH /users/me`	CURRENT_DIFFERENT_CONTRACT	Add address, lat/lng	any session
PUT /me/fcm-token	`PUT /users/me/fcm-token`	CURRENT_DIFFERENT_CONTRACT	Allow customer principal	any session
DELETE /me/fcm-token	`DELETE /users/me/fcm-token`	CURRENT_DIFFERENT_CONTRACT	same	any session
GET /shops/nearby	none	NEW_PROPOSED	`GET /customer/shops/nearby`	customer
GET /shops/{shopId}	`GET /public/shops/:slug`	CURRENT_DIFFERENT_CONTRACT	New `GET /customer/shops/{shopId}` returning rates, paper options, photos; public slug route unchanged	customer
GET /shops/{shopId}/reviews	none	NEW_PROPOSED	`GET /customer/shops/{shopId}/reviews`	customer
POST /uploads/presign	`POST /public/shops/:slug/uploads/initiate` + upload PUT (HMAC token)	CURRENT_DIFFERENT_CONTRACT	`POST /customer/uploads/presign` wrapping the same storage driver; keys scoped `uploads/{userId}/...`	customer
POST /orders	`POST /public/shops/:slug/orders`	CURRENT_DIFFERENT_CONTRACT	`POST /customer/orders` sharing pricing and validation	customer
GET /orders, GET /orders/{id}	`GET /public/orders/:token` (capability)	CURRENT_DIFFERENT_CONTRACT	`GET /customer/orders`, `GET /customer/orders/{id}`	customer
GET /orders/{id}/file	shop document routes	CURRENT_DIFFERENT_CONTRACT	**BLOCKED** while 30-minute retention stands (D3): not offered to customers. If 7-day retention is separately approved: `GET /customer/orders/{id}/file` (short-lived URL, 410 after deletion). Shop access stays on shop routes	customer
POST /orders/{id}/cancel	cancel is shop-side only today	NEW_PROPOSED	`POST /customer/orders/{id}/cancel` (NEW/ACCEPTED only)	customer
POST /orders/{id}/payment	none	NEW_PROPOSED	`POST /customer/orders/{id}/payment` (UTR)	customer
POST /reviews	none	NEW_PROPOSED	`POST /customer/reviews`	customer
GET /shops/mine	`GET /shops/me`	CURRENT_DIFFERENT_CONTRACT	New `GET /shops/mine` from `Membership`; `/shops/me` unchanged	owner
PATCH /shops/{id}	`PATCH /shops/me`, `PUT /shop/settings`	CURRENT_DIFFERENT_CONTRACT	`PATCH /shops/{shopId}`; owner may not set verified/status	owner + membership
PUT /shops/{id}/rates	`/shop/pricing-rules`	CURRENT_DIFFERENT_CONTRACT	Keep per-sheet; no PDF per-page endpoint until approved	owner
PUT /shops/{id}/paper-options	none	NEW_PROPOSED	`PUT /shops/{shopId}/paper-options`	owner
POST /shops/{id}/images	none	NEW_PROPOSED	`POST /shops/{shopId}/images` (storage key, ownership, size, type, HEAD check)	owner
GET /shops/{id}/orders	`/shop/orders*`	CURRENT_DIFFERENT_CONTRACT	`GET /shops/{shopId}/orders` thin adapter	owner
PATCH /shops/{id}/orders/{oid}/status	`/shop/orders/:id/*` transitions	CURRENT_DIFFERENT_CONTRACT	Adapter over the single state machine (08)	owner
PATCH .../payment	none	NEW_PROPOSED	`PATCH /shops/{shopId}/orders/{orderId}/payment`	owner
POST /admin/shops	`POST /admin/shops`	CURRENT_DIFFERENT_CONTRACT	Keep; remove nothing. No reuse-by-phone	admin + 2FA

PDF endpoint	Existing route	Label	Proposed route / adapter	Auth
GET /admin/shops	`GET /admin/shops`	CURRENT_LIVE (filter `isVerified` NEW)	add filter	admin
PATCH /admin/shops/{id}/verify	none	NEW_PROPOSED	with AuditLog	admin
PATCH /admin/shops/{id}/block	`PUT /admin/shops/:id` (status)	CURRENT_DIFFERENT_CONTRACT	thin wrapper	admin

DEPRECATED: none introduced. Existing deprecated route is documented in `docs/architecture/api-inventory.md`.

Rules for every NEW_PROPOSED route: strict body schema, per-principal rate-limit bucket, tenant check from the session (never from the client), `Idempotency-Key` on creates, audit for privileged changes.

06 – Security and auth design (proposed)

Why the PDF token model is not adopted

The PDF sends a Firebase ID token on every call. The repository issues its own short-lived access token and a single-use rotating refresh token bound to an installation id, with reuse detection, replay protection on Firebase `auth_time`, per-family revocation and Admin TOTP. Sending raw ID tokens to every route would remove revocation, device binding and the rotation guarantees. Decision AD-3: keep the current model for all clients; Firebase stays an identity proof exchanged once.

Flows

Client	Flow
Customer Android (proposed)	Firebase Google or phone OTP, then `POST /auth` with `installationId`; response is an access and refresh pair with principal `CUSTOMER`. Refresh via `POST /auth/refresh`. Logout `POST /auth/logout`.
Shop-owner Android (live)	Unchanged: `POST /auth` (Google, OTP, email+password). Multi-shop adds `GET /shops/mine`; the selected shop is a path parameter checked against `Membership`.
Web shop dashboard (live)	Cookie session + `X-CSRF-Token`. Legacy `/shop/*` uses the default shop.
Admin panel (live)	Password + TOTP 2FA (`printout_2fa` challenge), web only. New verify/block actions require the existing admin session and re-auth rules.
Windows Agent (live, untouched)	Device credential `pbd_...`; no user token.

Rules

1. Identity linking is explicit and re-authenticated; email or phone equality never links or signs in. The PDF steps "claim record by phone" and "reuse user by phone" are not implemented.
2. A person who is both customer and owner uses separate role grants on one account only after an explicit link; otherwise two accounts.
3. Tenant isolation: every `/shops/{shopId}/...` handler resolves `shopId` through `Membership(userId)`; failure is 403/404 without disclosing existence. Customers only see their own orders (`customerUserId`).
4. Customer-visible shop payloads exclude owner email, phone of owner, device and billing data.
5. Suspended accounts: existing `ACCOUNT_BLOCKED` behaviour; add `User.isActive` check for customers on login and refresh.
6. FCM: a token already registered to another user is **not** silently reassigned. The old registration is revoked only after the new principal authenticates in the same request, the action is audited, and registrations are keyed by `(userId, installationId)` as today. (The PDF's "reassign" is acceptable only under this rule.)
7. Uploads: type allowlist by magic bytes, size cap, object-key prefix bound to the authenticated principal, existence HEAD check, no cross-user or cross-shop reuse of a key.
8. Payments: a submitted UTR is an unverified claim, never proof. No automatic `paid`. Shop owner only sets `paid`. Refunds need a defined permission (proposed: admin only, as in the PDF). No card, PIN or bank credentials are stored.
9. Reviews: customer of a completed order only; text escaped on render; per-user rate limit.
10. Audit: every privileged change records actor, target, before and after in `AuditLog.metadata`. Append-only enforcement is an open decision.
11. Rate limits: add buckets for customer read, customer mutation, presign (per hour), review.

07 – Migration plan (proposed; nothing applied)

Strategy: expand, migrate, verify, contract. This release only expands. No drops, no renames, no retyping, no resets. Applied migrations are never edited.

Step	Migration (new, forward-only)	Backfill	Verification
M1 identity	`Role` + `CUSTOMER`; `User.email` nullable (with partial unique); `User` address, lat/lng, `isActive` default true; `UserRoleGrant`	one grant per user from `User.role`	row counts, `migrate diff` clean
M2 shop profile	`Shop` new nullable columns; `isVerified` default false	set `isVerified=true`, `verifiedAt=now()` for all existing ACTIVE shops so none leaves discovery	no ACTIVE shop unverified after backfill
M3 shop media/paper	`ShopPaperOption`, `ShopImage`	seed paperSize from distinct `PricingRule.paperSize`	counts match
M4 geo	btree index on `(latitude, longitude)` and `(isVerified, status)`. PostGIS (`CREATE EXTENSION`, `geography`, GiST) is a **separate, later** migration (D4: approved in principle, pending confirmation) gated on non-production testing, migration review and a production permission check (`SELECT * FROM pg_available_extensions WHERE name='postgis'`; operator may need superuser or a provider toggle)	derive geography from lat/lng	EXPLAIN on nearby query
M5 order	`Order` nullable `customerUserId`, `paymentMethod`, `paymentStatus`, `note`, `paperType`, `acceptedAt`, `completedAt`, `isReviewed`; `OrderStatus` + `REJECTED` (its own migration, after clients tolerate unknown statuses, D7); index `(customerUserId, createdAt)`	`acceptedAt` / `completedAt` from `OrderStatusHistory`; old rows keep null customer	historical orders readable by existing queries
M6 payment/review	`OrderPayment`, unique `(shopId, upiTxnRef)` where not null; `Review` unique `orderId`, check 1..5; `UserNotification`	none	
M7 audit	none (action names only)	none	

Risks: (a) nullable-email unique index semantics (Postgres allows multiple NULLs; confirm no code assumes non-null email: `grep` of `user.email` consumers required before M1). (b) `ALTER TYPE ADD VALUE` cannot run inside a transaction block on older PG; Prisma handles it, test on a disposable database. (c) Unique `(shopId, upiTxnRef)` must be partial. (d) Verified backfill must run in the same release as the discovery code.

Rollback: new tables and nullable columns can be dropped by a later approved migration; enum values stay. Application rollback is safe because old code ignores new columns. Before any production run: verified backup, restore trial to a disposable DB, `migrate deploy` there, `migrate diff` zero drift, explicit owner approval. Never run against production from this branch.

Existing data mappings: shop ownership (`User.shopId` and `Membership` already agree after the earlier backfill; re-verify), auth identities (untouched), devices/printers/jobs (untouched).

08 – Order and payment state machines (proposed)

Current machine (`apps/api/src/domain/lifecycle.ts`)

```
NEW -> ACCEPTED | CANCELLED | EXPIRED
ACCEPTED -> PRINTING | CANCELLED | EXPIRED
PRINTING -> PRINTED (print confirmation only) | EXPIRED (system only)
PRINTED -> READY
READY -> COLLECTED
COLLECTED, CANCELLED, EXPIRED: terminal
```

Cancellation today is shop-side only. There is no REJECTED state; no customer actor; PRINTED is set only by print confirmation (Windows agent / device flow).

PDF-to-current mapping (API aliases, no enum rename)

PDF status	Internal	Note
pending	NEW	
accepted	ACCEPTED	
printing	PRINTING	
(none)	PRINTED	Internal only; exposed to PDF-style clients as `printing`
ready	READY	
completed	COLLECTED	
cancelled	CANCELLED	actor customer or shop
rejected	new `REJECTED` (decision D7, owner preference pending)	Until the additive migration ships and every client tolerates unknown statuses, a shop reject is the existing NEW -> CANCELLED with a reason. Rollout order is in 02 D7
(none)	EXPIRED	Internal; PDF-style clients see `cancelled`

Target transition matrix

From	To	Actor	Conditions
NEW	ACCEPTED	shop owner (membership)	shop not blocked
NEW	REJECTED	shop owner	`rejectReason` required; after D7 rollout only
NEW	CANCELLED	customer (owner of order)	optional `cancelReason`
ACCEPTED	PRINTING	shop owner / print-now	existing print path, unchanged
ACCEPTED	CANCELLED	customer or shop	allowed until printing starts
PRINTING	PRINTED	print confirmation only	existing
PRINTED	READY	shop	
READY	COLLECTED	shop	optional rule: require `paymentStatus = paid` (PDF leaves this open, default allow)
any non-terminal	EXPIRED	system worker	existing

Rules: one module (`domain/lifecycle.ts`) is the only authority; routes and any PDF-style adapter call it. Each transition is one DB transaction that locks the order row, re-reads status (concurrency: loser gets 409 `INVALID_STATUS_TRANSITION`), inserts `OrderStatusHistory`, and writes the outbox notification. Push and SSE happen after commit; FCM failure never rolls back. Repeating the same target status by the same actor is idempotent (200, no new history). **No transition ever re-queues a physical print job**; retries stay in the device-job layer.

Customer cancel is blocked from PRINTING onward (409), matching the PDF.

Payment machine (customer to shop; not platform billing)

```
unpaid -> pendingVerification   customer submits UTR (UPI orders only)
pendingVerification -> paid     shop owner verifies
pendingVerification -> unpaid   shop owner rejects (customer may resubmit)
```

```
unpaid -> paid                  shop owner confirms cash
paid -> refunded                admin only (proposed; refund permission needs approval)
```

Controls: `(shopId, upiTxnRef)` unique where not null (409 `DUPLICATE_UTR`); concurrent updates use row lock and compare-and-set on `paymentStatus`; every change is audited and appended to a payment history; a UTR is a claim, not proof; no automatic `paid`; no gateway.

Order status and payment status stay independent (a COLLECTED order may be unpaid).

09 – Storage and retention impact analysis

No retention change is made by this work. The owner must approve one of the options below.

Item	Current (`apps/api/src/config.ts`)	PDF target
After the first Print action	`PRINT_RETENTION_MINUTES` = 30 (`Document.deleteAfter`)	7 days after completed, cancelled or rejected
Never printed	`UNPRINTED_RETENTION_HOURS` = 24	orphan upload deleted after 24 h; unused-by-order
Max upload	`UPLOAD_MAX_BYTES` 50 MiB (ceiling 100 MiB)	20 MB
Signed URL	upload token 15 min; HMAC download for local driver	download 2 to 5 min
Receipt	`DeletionReceipt` model exists (unused)	`fileDeletedAt`
Notification retention	14 days	not specified

Impact of moving 30 minutes to 7 days

- **Privacy**: customer documents (IDs, forms, financial papers) would sit in storage about 336 times longer; the product's privacy notice and any customer consent text would have to change before launch; the web `RetentionNotice` component and API field `retentionMinutes` expose today's promise.
- **Cost**: storage = average daily upload volume x 7. At 1,000 orders/day of 2 MB, about 14 GB steady state; low cost, but backup size grows.
- **Backups**: files must be excluded from, or aged out of, backups; otherwise deletion is not real.
- **Windows spool and Android local copies**: deleting the R2 object does not delete local spool/cache files. Those follow the agent/device policy and are a separate deletion path; do not claim deletion of originals covers them.
- **Active and failed jobs**: the worker must not delete a document while a `DevicePrintJob` or order is still non-terminal; the existing `Document.status` machine (`PRINTED_RETENTION`, `deletionAttempts`, `lastDeletionAttemptAt`) already supports retry; keep it idempotent and restart-safe.
- **Guest QR uploads**: they have no order account; the 24 h unprinted rule remains; any 7-day rule would apply only to authenticated customer orders if approved (a per-source policy is an option).
- **Re-download for customers** (`GET /orders/{id}/file`) is the product reason for 7 days; an alternative is to keep 30 minutes and omit that endpoint.

Options

A. Keep 30 minutes; customer file download endpoint not offered. B. Per-source: 30 minutes for guest, 7 days for authenticated customer orders. C. 7 days for all.

Owner preference recorded (02 D3, pending confirmation): option A. Recommendation: A for the first release, with B revisited once a privacy notice is drafted. Implementation of any option stays behind configuration plus a worker update; cleanup must remain idempotent with storage-failure retries.

10 – Android integration plan

Android must keep working with every live route. Nothing below changes a live contract; new routes are additive and labelled NEW_PROPOSED in 05.

Area	Today (live)	Plan	Compatibility
Sign-in	`POST /auth`, refresh, logout	Same endpoints; customer principal is a new `nextStep`/role value that older apps ignore	additive field only
Profile	`GET/PATCH /users/me`	extra optional fields	additive
FCM	`PUT/DELETE /users/me/fcm-token`	same routes, customer allowed	unchanged
Owner shops	`GET /shops/me`	`GET /shops/mine` + shop selector; each call carries shop id in the path	old route stays
Orders (owner)	`/shop/orders*`, device order routes	adapter `GET /shops/{shopId}/orders`	old routes stay
Customer app	none	new `/customer/*` routes, same token mechanics	new app only
Status display	NEW..COLLECTED	clients keep internal values; PDF-style names are a presentation mapping (08)	no enum break
Payments/reviews	none	new fields optional	additive

Rollout order: (1) docs and OpenAPI agreed with the Android developer, (2) additive backend release, (3) Android feature flags, (4) customer app. Android must tolerate unknown enum values and unknown fields (strict bodies apply to *requests* only).

Matrix and detailed samples for the live routes are in `docs/architecture/android-integration-guide.md` (PR #44). Request and response samples for NEW_PROPOSED routes are deliberately not published as contracts until the owner approves the decisions in 02.

11 – Phase implementation roadmap

Each phase: own branch from `development` after `development` is re-synced with `main` (see 12, branch base), own PR, migrations only if listed, tests, review, CI green, rollback plan, compatibility report. Nothing deploys automatically.

Phase	Scope	Migrations	Blocked on
0	This documentation PR	none	review
1 Identity + multi-shop	`CUSTOMER` role, `UserRoleGrant`, nullable email, `GET /shops/mine`, `Membership` checks on new routes	M1	AD-3 and D5 confirmation; email-null audit
2 Discovery	shop profile columns, verification flag + admin verify/block + audit, paper options, shop images, nearby search (PostGIS per D4, haversine fallback behind one interface)	M2, M3, M4	D4 confirmation, non-production PostGIS test, production permission check; address model
3 Customer ordering	customer uploads, order create via shared pricing, history, customer cancel	M5	D2 (per-sheet quotes), D3 (30-min retention; no customer file download)
4 Lifecycle + payments	state-machine adapter, reject, cash/UPI tracking	M6	D6, D7 rollout order, refund permission; Phase B coordination
5 Reviews + notifications	reviews, rating aggregate, customer FCM, `UserNotification`	M6	
6 Retention + rollout	retention only if separately approved (D3 keeps 30 min), worker alignment, Android, web, regression, staged release	config	D3

Safe foundation work that needs no policy decision, proposed as the first implementation PR after this one: tests that pin the current lifecycle and `/public` contract (regression net), then M1 additive migration on a disposable database.

12 – Risk and rollback plan

#	Risk	Likelihood	Impact	Mitigation	Rollback
1	Making `User.email` nullable breaks code assuming non-null	medium	high	grep and type-check all consumers first; keep partial unique	old code ignores new rows; revert app, keep column
2	Per-page vs per-sheet mispricing	high if naive	high (money)	keep per-sheet, never convert silently	none needed (not built)
3	Switching to Firebase ID tokens on every call	n/a	critical	rejected (AD-3)	n/a
4	Auto-linking by phone/email (PDF login/admin-create)	n/a	critical account takeover	rejected (AD-6)	n/a
5	Retention raised to 7 days without notice	medium	privacy	owner approval (09)	revert config; worker deletes backlog idempotently
6	PostGIS unavailable or extension needs superuser	medium	blocks geo	test on a disposable PostGIS DB; check `pg_available_extensions`; keep a haversine fallback behind the repository interface	no extension created
7	Unverified backfill hides existing shops	low	revenue	backfill `isVerified=true` in same release	set flags back
8	New `REJECTED` enum breaks Android/agent	medium	high	clients tolerate unknown statuses before the value is added (D7)	enum value is inert if unused; reject action behind a flag
9	Duplicate printing from status replays	low	high	no transition re-queues print jobs; retries stay in device-job layer	n/a
10	Overlap with Phase B (printers, device jobs)	high	merge conflict	leave `Device*` / `PrintAgent` / `Printer` untouched; coordinate	n/a
11	FCM token reassignment across users	medium	privacy	rule 6 in 06	revoke registrations
12	UTR treated as proof of payment	medium	financial dispute	shop-only `paid`; wording in UI	n/a

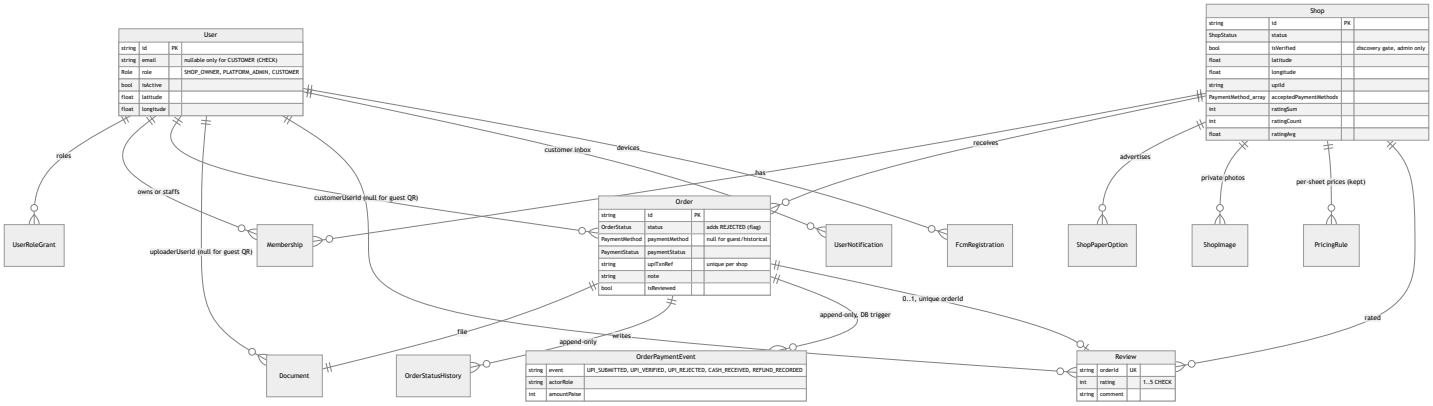
| 13 | `development` is behind `main` (9 commits on `main` not in `development`, 26 the other way); a PR based on either can carry or miss unrelated changes | high | merge conflicts, features built on stale code | Docs-only PRs are safe on either base. Before Phase 1 code: merge `main` into `development` via the existing sync-PR pattern (`chore/sync-hotfix-34-to-development`), verify CI, then branch Phase 1 from `development`. Never rewrite either branch | n/a |

Global rules: backup and restore trial before any production migration; disposable databases for tests; no production writes, deploys or pushes to long-lived branches without explicit approval; preserve the Print-keep bundle, Android/UI patches, backups, env files and the recovery key.

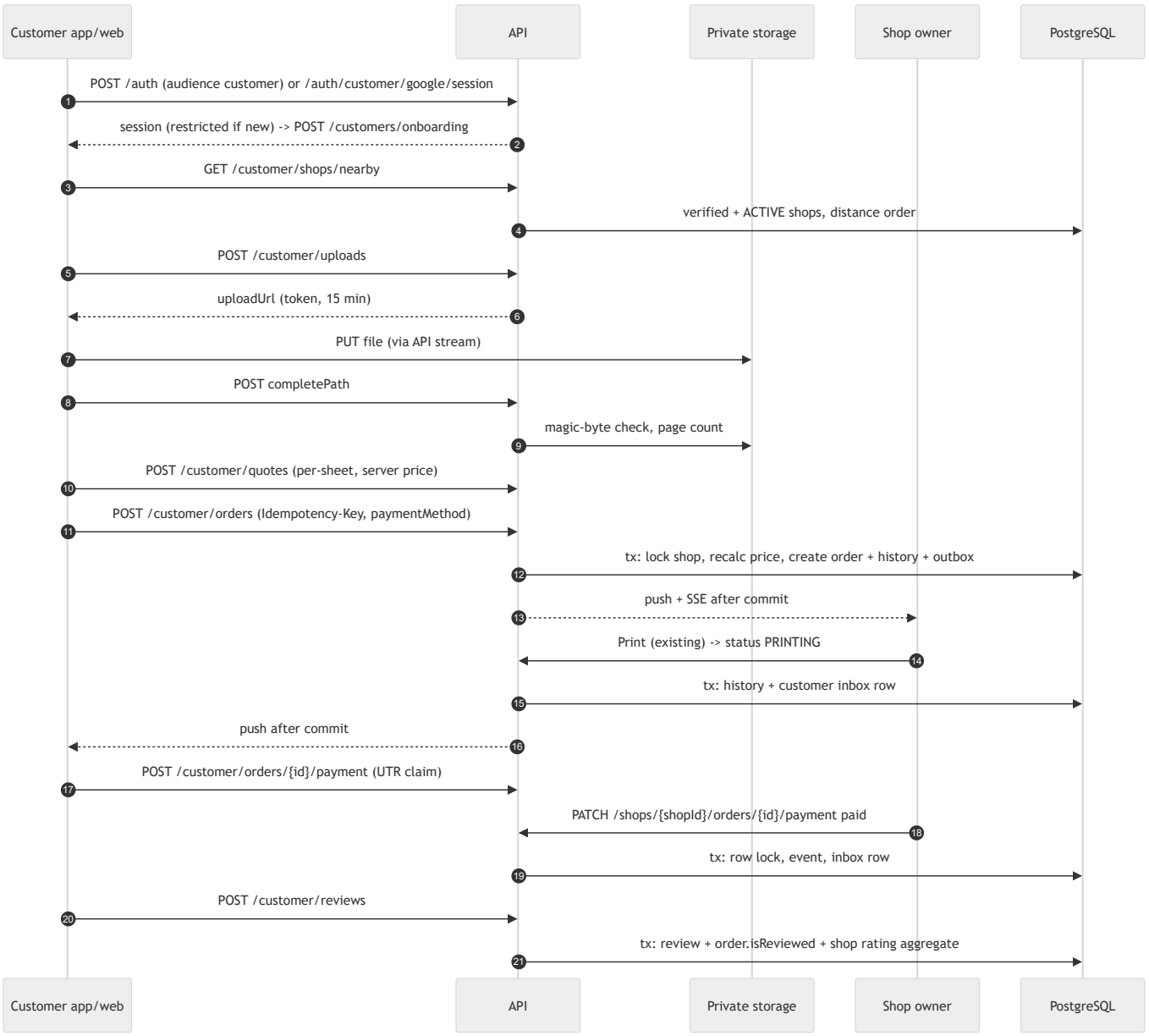
13 – Final ER and sequence diagrams (as implemented)

Source of truth: `apps/api/prisma/schema.prisma` and the migrations `20261028100000` to `20261028140000`. Status per `IMPLEMENTATION_PROGRESS.md`.

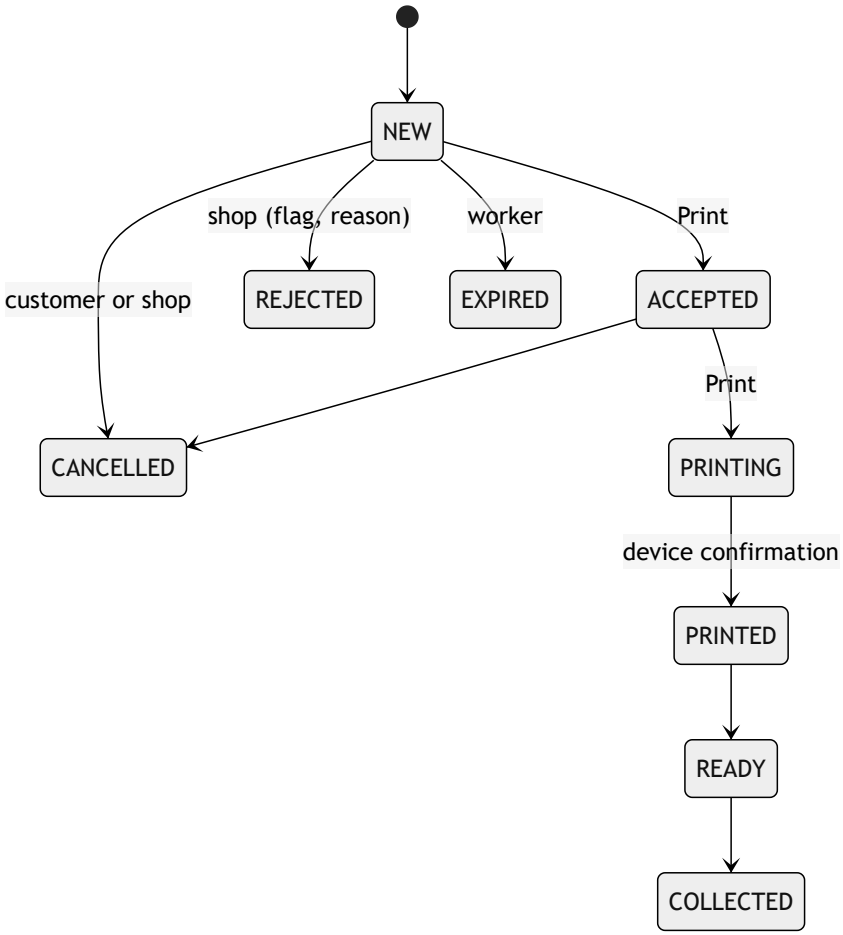
Entity relationships added by Schema V2

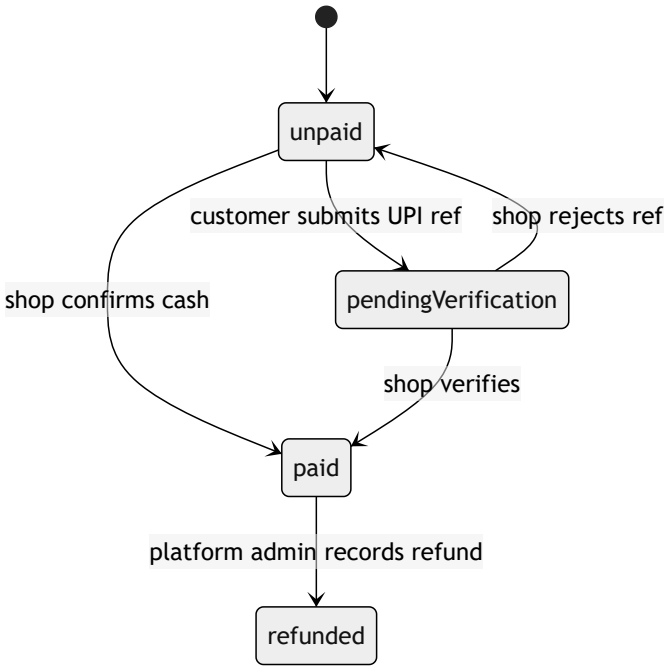


Customer order, payment and review

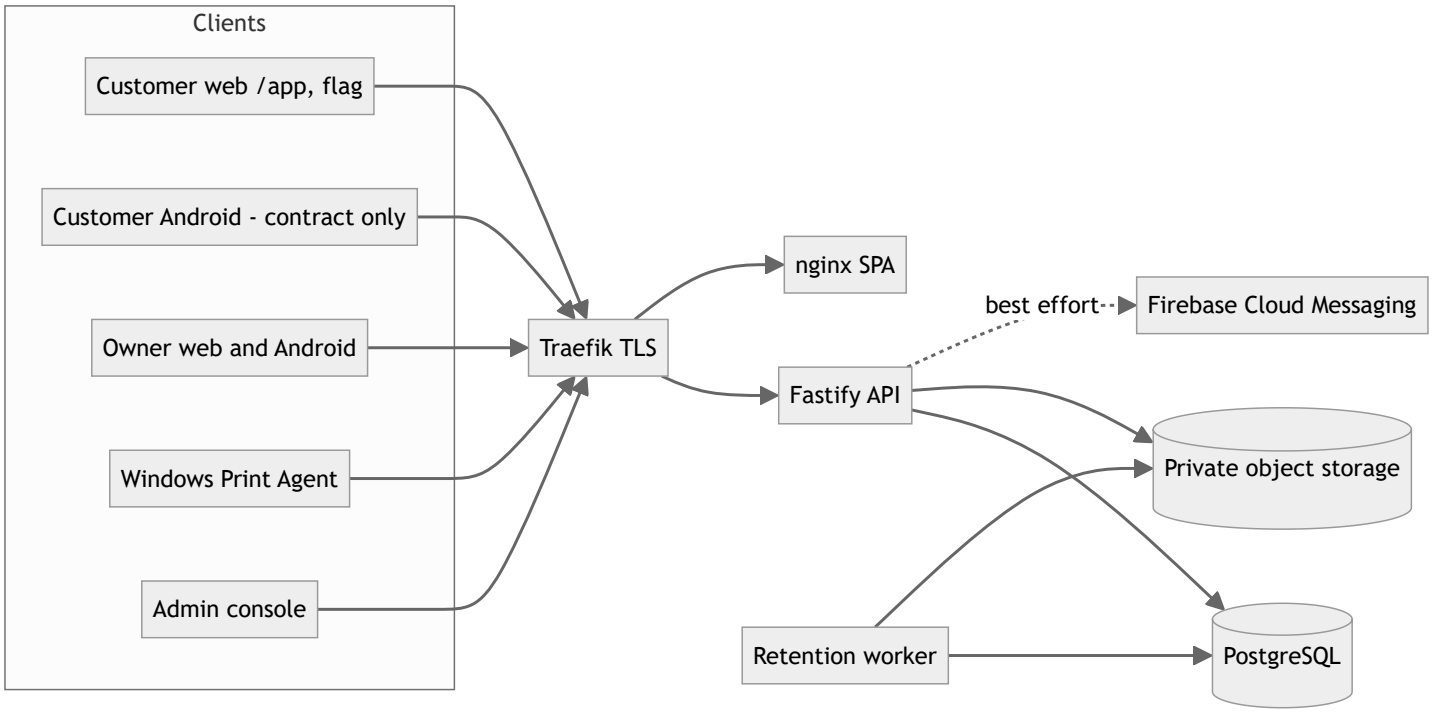


Order status and payment status (independent)





System overview


Clients
Customer web /app, flag
Customer Android - contract only
Owner web and Android
Windows Print Agent
Admin console
Traefik TLS
nginx SPA
Fastify API
best effort
Firebase Cloud Messaging
Private object storage
Retention worker
PostgreSQL

PostGIS runbook (decision D4)

Status: **the application ships without a PostGIS dependency.** Nearby search runs on the portable haversine repository (`GEO_BACKEND=haversine`, default). PostGIS is an optional accelerator, enabled by an operator only after every check below passes. `GEO_BACKEND=postgis` falls back to haversine automatically if the extension is not installed, so the flag can never break discovery.

What was verified (disposable `postgis/postgis:16-3.4`, PostGIS 3.4.3)

- All repository migrations apply; `prisma migrate diff` reports no drift with the GiST index present (the index is an expression index that Prisma ignores).
- `apps/api/test/schema-v2-postgis.test.ts` (7 tests, runs only with `POSTGIS_TEST_DATABASE_URL`): identical shops, order and totals vs the haversine repository at 1/5/20 km (distances within 0.2 km), unverified shops never returned, pagination totals, automatic fallback when the extension is absent.
- `prisma/postgis/enable.sql` is idempotent (`CREATE EXTENSION IF NOT EXISTS`, `CREATE INDEX CONCURRENTLY IF NOT EXISTS`).

Production pre-flight (read-only; all must pass)

1. `SELECT version();` and `SHOW server_version;` - supported major version.
2. `SELECT name, default_version FROM pg_available_extensions WHERE name = 'postgis';` - the package is installed on the server. If no row: **stop**, PostGIS is not available; keep `GEO_BACKEND=haversine` and report PostGIS pending.
3. `SELECT rolsuper, rolcreatedb FROM pg_roles WHERE rolname = current_user;` and, for managed databases, whether the provider allows `CREATE EXTENSION postgis` for the application role (often a dashboard toggle). If privileges are missing, **stop**.
4. A fresh backup exists, a restore of it has been tested on a disposable database, and an independent off-server copy exists.
5. Row count of `Shop` (small) and current query latency baseline for `GET /customer/shops/nearby` on a copy.
6. Maintenance risk: `CREATE EXTENSION` takes a brief catalogue lock; `CREATE INDEX CONCURRENTLY` does not block writes.

Enable (only after the pre-flight passes)

```
psql "$DATABASE_URL" -c "CREATE EXTENSION IF NOT EXISTS postgis;"
psql "$DATABASE_URL" -c 'CREATE INDEX CONCURRENTLY IF NOT EXISTS "Shop_location_gist" ON "Shop" USING gist
((ST_SetSRID(ST_MakePoint("longitude","latitude"),4326)::geography)) WHERE "latitude" IS NOT NULL;'
```

Then set `GEO_BACKEND=postgis`, restart the API, and run the nearby smoke test (same shop ids and order as before). Verify with `EXPLAIN` that the GiST index is used once the table has meaningful size.

Rollback

Set `GEO_BACKEND=haversine` and restart (immediate, no data change). The extension and index can stay; dropping them (`DROP INDEX "Shop_location_gist"`) is optional and separate.

Phase 1 contract: identity and multi-shop

Status of every item below: **IMPLEMENTED on branch `feature/daksh-schema-v2-phase1-identity`; becomes CURRENT_PRODUCTION only when `IMPLEMENTATION_PROGRESS.md` says DEPLOYED with evidence.** All routes are additive; no existing response shape or route changed.

Compatibility rules (Android and web)

- `POST /auth` gains an **optional** body field `audience`: `"shop"` (default, identical to today) or `"customer"`. The existing owner app never sends it, so its behaviour is unchanged. A customer identity signing in without `audience: "customer"` still gets the existing `403 FORBIDDEN`; an owner identity with `audience: "customer"` gets `403 FORBIDDEN`. `loginMethod: "email"` with `audience: "customer"` is `400`.
- New response values (only ever returned to customer accounts or `audience: "customer"` requests): `user.role = "customer"`; `nextStep = "create_customer"` (restricted grant, call `POST /customers/onboarding`) or `"customer_home"`. `user.email` may be `null` for customers.
- The existing owner contract (`nextStep` values `dashboard`, `complete_profile`, `create_shop`, `generate_qr`, `account_blocked`, `shops` of length 0 or 1, `/shops/me`) is unchanged. `/shops/mine` is additional.
- Customer sessions use the same bearer/refresh mechanics as owners (`/auth/refresh`, `/auth/logout`).

New routes

Route	Auth	Notes
`POST /customers/onboarding`	restricted onboarding grant (bearer for mobile, cookie for web)	Body `{ name, client, deviceId? }`, strict. Flag `CUSTOMER_SIGNUP_ENABLED` (default off, else `403 CUSTOMER_SIGNUP_DISABLED`). `201` created / `200` idempotent retry; `409 ALREADY_ONBOARDED`, `409 PHONE_UNAVAILABLE` / `GOOGLE_IDENTITY_UNAVAILABLE`. Creates a `CUSTOMER` user (no password, no shop) + `UserRoleGrant` + verified identity in one transaction. If the Google email already belongs to another account the customer is created with `email = null`; nothing is merged or revealed.
`GET /customers/me`	customer session	The standard profile (`role: "customer"`, `shops: []`) plus `customer: { addressLine1, addressLine2, city, state, pincode, latitude, longitude }`.
`PATCH /customers/me`	customer session	Strict body: `name`, address fields, `pincode` (6 digits), `latitude` + `longitude` (sent together, valid ranges). Unknown keys (role, isActive, shopId, email) are `400`. Audited by field name only.
`GET /shops/mine`	owner session	`{ data: { items: [{ id, slug, shopName, shopStatus, isActive, acceptsOrders, isDefault, createdAt }], page, limit, total, defaultShopId } }`. The default shop (`User.shopId`) plus shops where the caller has an `OWNER` membership. `STAFF` memberships and other tenants never appear.

Authorization model

- `User.role` stays the primary role used by guards. `UserRoleGrant` records roles (backfilled; new owners and customers get a row). Grants never confer access by themselves and the API never creates `PLATFORM_ADMIN` grants.
- Customers: `customerGuard` (CUSTOMER role only). Owner routes (`shopGuard`) and admin routes (`adminGuard`) already require their own role, so customers are refused (403) everywhere else.
- `requireOwnedShop(userId, shopId)` is the single check for future `/shops/{shopId}/...` routes: unknown and foreign shops are both `404`.
- `User.isActive = false` blocks the account (`403 ACCOUNT_BLOCKED`) on use, sign-in and refresh.
- Identity is resolved only by Firebase uid. Matching email or phone never links, signs in or merges accounts (AD-6).

Database (migrations `20261028100000_customer_role_enum`, `20261028100100_customer_identity_foundation`)

Additive only: `Role` + `CUSTOMER`; `User.email` nullable with `CHECK (role = 'CUSTOMER' OR email IS NOT NULL)`, `CHECK (role <> 'CUSTOMER' OR shopId IS NULL)`, coordinate range and pairing checks; customer address, coordinates and `isActive` columns; `UserRoleGrant` table; restartable backfill of one grant per user and an `OWNER` membership per owner's default shop. Verified on a disposable PostgreSQL 16 upgrade with seeded data (counts unchanged, backfill correct, constraints enforced, `prisma migrate diff` clean). Rollback: application code ignores the new objects; the enum value cannot be removed.

Android notes

Existing owner app: no change required. Customer app (not in this repository): send `audience: "customer"` on `POST /auth`; if `nextStep == "create_customer"` call `POST /customers/onboarding` with the restricted access token, then use the returned pair like an owner pair.

Phase 2 contract: discovery

Status: **IMPLEMENTED on branch `feature/daksh-schema-v2-phase2-discovery`; becomes CURRENT_PRODUCTION only when `IMPLEMENTATION_PROGRESS.md` says DEPLOYED with evidence.** All routes are additive; no existing route changed except two additive fields on the admin shop view (`isVerified`, `verifiedAt`) and an optional `isVerified` filter on `GET /admin/shops`.

Customer routes (customer session; owners/admins get 403, anonymous 401)

Route	Notes
`GET /customer/shops/nearby?lat&lng&radiusKm&printingType&page&limit`	`lat` -90..90, `lng` -180..180 required; `radiusKm` default 5, max 20 (above 20 is `400`); `printingType` `colored` or `blackWhite` (shops with an active rate of that colour mode); `limit` default 20, max 50. Response `{ data: { items: [card + distanceKm], page, limit, total } }`, ordered by distance then id. Only **verified, ACTIVE shops with coordinates**. Closed shops are listed with `isOpen: false`. Rating is not ranked yet (no ratings until phase 5). Unknown query keys are `400`.
`GET /customer/shops/{shopId}`	Card plus `location`. Unverified, suspended or unknown shops are `404`.
`GET /customer/shops/{shopId}/images/{imageId}`	Streams a private photo through the API (`content-type` from the verified type, `nosniff`, `private` cache). Never a storage URL.

Card fields: `id, shopName, phoneNumber, addressLine1/2, city, state, pincode, isOpen, acceptsOrders, availability{state,reason,nextOpenAt,closesAt,orderingBlocked}, rates[{paperSize,colourMode,sides,pricePerSheetPaise}], paperSizes, paperTypes, images[{id,url,sortOrder}], ratingAvg (null), ratingCount (0)`. Prices are **per sheet** (decision D2); the authoritative price is always recalculated server-side at quote/order time. No owner email/phone, devices, subscription or audit data is ever returned.

Owner routes (owner session; `/shops/{shopId}` is checked against the caller's own shops, a foreign id is `404`)

Route	Notes
`GET /shops/{shopId}`	Card plus `shopStatus, isActive, isVerified, verifiedAt, country, slug`.
`PATCH /shops/{shopId}`	Strict body: `shopName, phoneNumber (E.164 or null), addressLine1, addressLine2, city, state, pincode, latitude+longitude (together), isOpen`. `isVerified`, `status`, `isActive`, `slug` are `400`. `isOpen: true` needs an ACTIVE shop (`422 SHOP_NOT_ACTIVE`) and at least one active rate (`422 RATE_NOT_SET`); closing is always allowed. `isOpen` maps to the existing `acceptsOrders`. Deviation from the PDF: opening does **not** require verification, because verified-only would break guest QR ordering of existing/new shops; verification gates *discovery* only.
`PUT /shops/{shopId}/paper-options`	`{ paperSizes[], paperTypes[] }`. A size can be advertised only if the shop has an active rate for it; the only paper type priced today is `normal` (others `400 UNSUPPORTED_PAPER`, no A3/glossy/matte claims). Atomic replace; audited.
`POST /shops/{shopId}/images`	Raw body `image/jpeg` or `image/png`, max 2 MiB, magic-byte verified (the declared type is ignored), max 8 photos (`409`), opaque random storage key, DB row `ShopImage`. `201 { id, url, sortOrder }`.
`GET /shops/{shopId}/images/{imageId}`, `DELETE ...`	Owner view and removal (`204`; object deleted).

Admin routes (admin session + 2FA as today)

Route	Notes
`GET /admin/shops?isVerified=true|false`	Verification queue.
`PATCH /admin/shops/{id}/verify`	`{ isVerified }`; sets `verifiedAt/verifiedBy`; audit `shop.verify` / `shop.unverify` with `{before, after}`. Idempotent.
`PATCH /admin/shops/{id}/block`	`{ isActive }`; block = `SUSPENDED` with the same immediate session/refresh lock-out as `PUT /admin/shops/:id`; unblock only lifts `SUSPENDED` (a `PILOT` shop is untouched). Audit `shop.block` / `shop.unblock`.

Database (migration `20261028110000_shop_discovery`)

Additive: `Shop` address line 2, city, state, country (default `IN`), latitude, longitude (range and pairing CHECKs), `isVerified`, `verifiedAt`, `verifiedBy`, indexes `(isVerified,status)` and `(latitude,longitude)`; tables `ShopPaperOption` (CHECK `kind IN ('paperSize','paperType')`) and `ShopImage`. Backfill (restartable): every existing ACTIVE shop is marked verified so none leaves discovery; paper sizes are seeded from each shop's active pricing rules.

Verified on a disposable PG16 upgrade with seeded shops (ACTIVE verified, PILOT not; sizes A3 and A4 seeded) and `prisma migrate diff` shows no drift.

Geo backend

`GEO_BACKEND=haversine` (default): bounding-box + haversine, no extension. `postgis`: ST_DWithin on a geography, optional GiST index; falls back automatically if the extension is missing. See `POSTGIS_RUNBOOK.md`.

Android notes

Existing owner app: no change. Customer app: use the three customer routes above; show `isOpen` / `availability` from the server (never from the device clock); image `url` values are API paths to be fetched with the bearer token.

Phase 3 contract: customer orders

Status: **IMPLEMENTED on branch `feature/daksh-schema-v2-phase3-orders`; becomes CURRENT_PRODUCTION only when `IMPLEMENTATION_PROGRESS.md` says DEPLOYED with evidence.** Additive. The guest QR flow (`/public/...`) is unchanged in behaviour; its order-creation code now lives in `domain/order-create.ts` and is shared (119 existing order/upload/lifecycle/hours/tenant tests pass unchanged). One tightening: the guest quote now refuses documents uploaded by an authenticated customer.

All routes below require a **customer session** (owners, admins: 403; anonymous: 401). Envelope `{ data }` / `{ error }` as everywhere else.

Flow

1. `POST /customer/uploads { shopId, fileName, byteSize, declaredMimeType }` (pdf, jpeg, png; `byteSize` 1..50 MiB). Shop must be verified, ACTIVE, accepting orders and open by hours (`404 SHOP_NOT_FOUND`, `409 SHOP_UNAVAILABLE`, `409 SHOP_CLOSED`). Limit: 50 uploads per customer per hour (`429`, counted in the database). Returns `{ uploadId, uploadUrl, requiredHeaders, completePath, expiresAt, limits }`.
2. `PUT uploadUrl` with the raw file and the required `content-type` (token-protected, single-use, 15 min, streamed to private storage; this is the existing pipeline).
3. `POST {completePath}` (no body): the server checks the real file type by magic bytes, counts pages and returns `{ documentId, pageCount, documentStatus: "AVAILABLE", ... }`.
4. `POST /customer/quotes { shopId, documentId, printOptions }` -> `{ quoteId, shopId, totalPaise, ..., expiresAt }`. `printOptions`: `paperSize "A4"`, `paperType "normal"` (optional), `colourMode bw|colour`, `sides single|duplex`, `copies 1..50`, `pageSelection`. Any other paper size or type is `400`: only A4 plain paper is priced today. Unknown keys (including any client price) are `400`.
5. `POST /customer/orders { quoteId, clientRequestId? , note? }` plus optional `Idempotency-Key` header (UUID; header and body must agree; one of them is required). `note` max 500. Returns `201` with the order view. The price is **recalculated by the server from the shop's current per-sheet rules** (integer paise, duplex handled by the same engine as the guest flow); the quote token carries no price.
6. `GET /customer/orders?status&page&limit` (limit max 50), `GET /customer/orders/{id}` (adds `statusHistory[{ status, by: customer|shop|system, reason, createdAt }]`), `POST /customer/orders/{id}/cancel { cancelReason? }`.

Order view: `id, orderNumber, shopId, shopName, status, totalPaise, currency, printOptions, priceSnapshot, fileName, pages, fileDeletedAt, note, createdAt, updatedAt`. Never returned: tracking token, storage key, actor ids, other customers' data.

Rules

- **Ownership**: a document is bound to its uploader; another customer, a guest, or a stolen quote token cannot quote or order it (`422 DOCUMENT_UNAVAILABLE`). A guest cannot consume a customer's document. An order or `clientRequestId` of another customer is a `404` / `409 IDEMPOTENCY_CONFLICT` with no data in the error (PDF's `403 NOT_ORDER_OWNER` is deliberately `404` so ids cannot be probed).
- **Idempotency** per (shop, clientRequestId): a replay by the same customer returns the same order; any other principal gets `409`.
- **Cancel**: only `NEW` or `ACCEPTED` and only before a print was initiated; compare-and-set so a concurrent shop action wins; idempotent for an already cancelled order; otherwise `409 INVALID_STATUS_TRANSITION`. Writes history (actor = customer), audit `order.cancelled_by_customer`, and emits the shop's SSE events after commit. (`REJECTED` and payments arrive in phase 4.)
- **Retention and files**: unchanged (decision D3): 24 h for unprinted documents, 30 minutes after print; the 50 MiB limit is kept. There is **no customer file re-download endpoint** (BLOCKED while retention is 30 minutes).
- **Windows Agent / devices**: untouched. Customer orders enter the same `NEW` queue and use the same print-now / device flow; nothing here can replay a physical print.

Database (migration `20261028120000_customer_orders`)

`Document.uploaderUserId` and `Order.customerUserId` (nullable, FK `SET NULL`, indexed), `Order.note` (CHECK <= 500). Guest rows keep NULL and are unaffected. Verified on a disposable PG16 with `prisma migrate diff` clean.

Android notes

Customer app: follow steps 1-6; show prices from `quote`/order responses only. Existing owner app: no change.

Phase 4 contract: lifecycle (REJECTED) and payments

Status: **IMPLEMENTED on branch `feature/daksh-schema-v2-phase4-lifecycle-payments`; becomes CURRENT_PRODUCTION only when `IMPLEMENTATION_PROGRESS.md` says DEPLOYED with evidence.** Additive. Platform stays free: this tracks what a customer owes a **shop**; there is no gateway, no automatic payment, no platform billing.

REJECTED (decision D7, flag `ORDER_REJECT_ENABLED`, default off)

- Migration `20261028130000_order_rejected_enum` adds the enum value only. Nothing sets it while the flag is off (`409 FEATURE_DISABLED`). **Rollout order:** ship clients that tolerate an unknown order status (web queue/tracking/history, Android owner and customer apps), then turn the flag on.
- `NEW -> REJECTED` by the shop, reason required (`400` without). Terminal. Refused while a payment is claimed or recorded (`409 PAYMENT_RECORDED`). Idempotent. Append-only history and audit as for every transition.
- Available through the existing `POST /shop/orders/:id/transitions` (`toStatus` now `CANCELLED` or `REJECTED`; the CANCELLED behaviour and contract are unchanged) and the new `PATCH /shops/{shopId}/orders/{orderId}/status { status: rejected|cancelled, rejectReason? }`. `accepted|printing|ready|completed` are refused with `409` (they are produced by the Print action and the device flow, not set directly).
- REJECTED is excluded everywhere CANCELLED/EXPIRED are: no document access, not counted as order value, hidden from active lists, no device print job. It reports with the cancelled orders in existing aggregate shapes.
- Windows Agent and device routes are unchanged; a rejected order can never be printed or replayed.

Payments

States (API spelling): `unpaid`, `pendingVerification`, `paid`, `refunded`; methods `cash`, `upi`. Order status and payment status are independent.

Action	Route	Rules
Choose method	`POST /customer/orders` `paymentMethod` (now **required** on this new route)	Must be accepted by the shop; UPI needs the shop's UPI ID, else `400 PAYMENT_METHOD_NOT_ACCEPTED`.
Shop payment settings	`PATCH /shops/{shopId}` `upiId`, `acceptedPaymentMethods`	`upiId` format `name@bank`; UPI cannot be accepted without a UPI ID and the ID cannot be removed while UPI is accepted. Default `["cash"]`. Customers see the UPI ID only when UPI is accepted.
Submit UPI reference	`POST /customer/orders/{id}/payment { upiTxnRef }`	8-22 letters/digits, normalised to upper case. `unpaid -> pendingVerification` only; **a claim, not proof**. `409 DUPLICATE_UTR` if the shop already has that reference on another order; `409 NOT_UPI_ORDER`; `409 INVALID_PAYMENT_TRANSITION` (already submitted, order closed).
Shop decision	`PATCH /shops/{shopId}/orders/{orderId}/payment { paymentStatus: paid|unpaid }`	Cash: `unpaid -> paid` (received). UPI: `pendingVerification -> paid` (verified) or `-> unpaid` (reference rejected and cleared; customer may resubmit). Anything else `409`. Only the shop owner of that order's shop; a customer can never mark paid. Orders without a method (guest QR) cannot be marked.
Manual refund record	`POST /admin/orders/{id}/refund { reason, amountPaise? }`	**Platform admin only.** `paid -> refunded`, reason 3-300 chars, amount 1..order total (default total). Records a refund made outside the platform; no money moves.

Concurrency: payment actions take a row lock on the order; of simultaneous identical decisions exactly one succeeds. A customer cannot cancel while a payment is claimed or recorded (`409 PAYMENT_RECORDED`) until the shop rejects the claim.

Evidence: every payment change appends an `OrderPaymentEvent` (event, from/to, reference, amount, reason, actor role) and an audit entry; a database trigger forbids UPDATE and DELETE of events.

Shop order list (multi-shop)

`GET /shops/{shopId}/orders?status&page&limit` returns `{ items, page, limit, total }` with `customerName` (display name only; never the customer's phone or email), print options, note, `paymentMethod`, `paymentStatus`, `upiTxnRef`. Foreign shop ids are `404`.

Database (migrations `...130000_order_rejected_enum`, `...130100_customer_payments`)

Enum `OrderStatus` + `REJECTED`; enums `PaymentMethod`, `PaymentStatus`; `Shop.upiId`, `Shop.acceptedPaymentMethods` (default cash); `Order.paymentMethod` (null for guest/historical orders), `paymentStatus` (default unpaid), `upiTxnRef` with unique `(shopId, upiTxnRef)`; table `OrderPaymentEvent` with CHECK constraints and the append-only trigger. Existing rows are unchanged; `prisma migrate diff` clean.

Android notes

Owner app: unchanged until the flag is on; then handle status `REJECTED` and optionally `PATCH /shops/{shopId}/orders/{orderId}/payment`. Customer app: send `paymentMethod`; for UPI show `payment.upiId`, collect the reference, call `.../payment`, and poll the order for `payment.status`.

Phase 5 contract: reviews, ratings, notifications

Status: **IMPLEMENTED on branch `feature/daksh-schema-v2-phase5-reviews-notifications`; becomes CURRENT_PRODUCTION only when `IMPLEMENTATION_PROGRESS.md` says DEPLOYED with evidence.** Additive. All routes require the stated principal; error envelope as everywhere else.

Reviews and ratings

Route	Notes
`POST /customer/reviews { orderId, rating 1..5 (integer), comment? <= 1000 }`	Customer of that order only (another customer's order, an unknown id: `404`). One review per order (`409 REVIEW_EXISTS`, also under concurrency). **Eligible once the shop's Print has started** (status `PRINTING`, `PRINTED`, `READY` or `COLLECTED`), else `422 ORDER_NOT_COMPLETED`. Assumption recorded: in this system the Print action is the shop's completion signal; the legacy ready/collected steps no longer exist in the shop UI, so waiting for `COLLECTED` would make reviews impossible. Cancelled, rejected, expired, new and accepted orders are refused. Comment: trimmed, control characters refused, blank means none, stored as plain text (**clients must escape on display**). 30 reviews per customer per 24 h (`429`). No edit and no delete in v1 (no such routes).
`GET /customer/shops/{shopId}/reviews?page&limit`	Verified ACTIVE shops only (else `404`). Newest first, `{ items: [{ id, rating, comment, customerName, createdAt }], page, limit, total, ratingAvg, ratingCount }`. `customerName` is abbreviated ("Alice B."); ids, emails and order ids are never returned.
`GET /shops/{shopId}/reviews`	Same payload for the owner of that shop (a foreign shop is `404`).

Aggregate: `Shop.ratingSum`, `ratingCount`, `ratingAvg` are updated in the same transaction as the review (row-locked order, atomic `UPDATE`), `ratingAvg = round(sum / count, 1)`, verified equal to `AVG(rating)` of the reviews table. Shop cards and the nearby list now return real `ratingAvg` (null while unreviewed) and `ratingCount`. Customer order views include `isReviewed`. Database CHECKs: rating 1..5, comment length; unique `orderId`.

Customer notifications

Events (generic texts with the order number only; no file names, amounts, payment references, reasons or contact data): order rejected, order cancelled by the shop, printing started, order expired (worker), payment received, payment reference not accepted (once per rejection), refund recorded. A customer's own cancellation and all guest QR orders produce nothing.

Route	Notes
`GET /customer/notifications?page&limit&unread=true`	`{ items: [{ id, type orderStatus|payment, title, body, orderId, readAt, createdAt }], page, limit, total, unreadCount }`, newest first. Own rows only.
`POST /customer/notifications/{id}/read`	`204`, idempotent (first `readAt` kept); another user's id is `404`.
`POST /customer/notifications/read-all`	`{ updated }`.

Delivery model: the inbox row is written **inside** the transaction that changes the order or payment (transactional outbox, unique per user and event), then a best-effort **push after commit**. A push failure never rolls anything back. Retention follows `NOTIFICATION_RETENTION_DAYS` (same worker as shop notifications).

Push (FCM)

- Customers register devices with the existing `PUT/DELETE /users/me/fcm-token` (now open to the `CUSTOMER` role as well as shop owners; admins still `403`) or the `fcmToken` field of `POST /auth`. Tokens stay encrypted at rest and are never returned. A token re-registered by another authenticated user moves to that user only (never shared).
- Customer pushes go only to that customer's own registrations (CUSTOMER role, active account); payload `{ type: order.updated|payment.updated, orderId, title }`. Shop owners get a push when a customer submits a UPI reference (`order.payment_submitted`). Dead tokens reported by FCM (`not-registered`, `invalid`) are revoked immediately; repeated failures revoke after `FCM_FAILURE_REVOKE_AFTER`; a total FCM outage is ignored by the request.
- Tested with a fake sender only; no real FCM calls were made.

Deferred to phase 6 (explicit)

Shop-owner in-app inbox rows for payment submissions and admin verification changes (the existing `ShopNotification` bell is built around new-order events and would mislabel other types until the web bell is updated in phase 6), and a push on verification/unverification. Nothing existing was changed for owners.

Database (migration `20261028140000_reviews_customer_notifications`)

`Shop.ratingSum/ratingCount/ratingAvg`, `Order.isReviewed`, tables `Review` (FKs `RESTRICT`) and `UserNotification` (CHECK `type`). Verified on disposable PG16; `prisma migrate diff` clean.

Schema V2 implementation progress

Status values: NOT_STARTED, IN_PROGRESS, IMPLEMENTED, TESTED, MERGED, DEPLOYED (only with verified production evidence), BLOCKED. Resume rule: a new session reads this file, `02-architecture-decisions.md` and the architecture skill, then continues at the first row that is not MERGED/DEPLOYED.

Production deployment record

Release	Evidence
Phases 1-4 DEPLOYED 2026-10-28 ~09:45 UTC to the production VPS (api + worker; web unchanged)	main merge `52b6a0b` (PR #54), tag `release-20261028-schemav2-p1-4`; 6 additive migrations `20261028100000` .. `20261028130100` applied (18 total, 0 failed); `/health` 200, `/ready` ready, read-only smoke 10/10 (`retentionMinutes=30` confirmed); new routes answer 401 unauthenticated; row counts unchanged (16 shops, 12 users, 27 orders, 44 documents); no error logs. Flags OFF: `CUSTOMER_SIGNUP_ENABLED`, `ORDER_REJECT_ENABLED`; `GEO_BACKEND=haversine`. Rollback images `printout-{api,web}:rollback-pre-schemav2-20261028`. Backups before deploy (age-encrypted, copied off-server to the operator laptop with matching sha256): `printout-20261028T092927Z`, `printout-20261028T093929Z`; restore rehearsal and migration rehearsal passed on a restored copy before deploying. NOTE: the scheduled backup job still has no off-server remote (`BACKUP_RCLONE_REMOTE` unset); off-server copies are manual until a remote is configured.

Production deployment record 2

Release	Evidence
Phase 5 + customer web app (flag OFF) DEPLOYED 2026-10-28 ~11:55 UTC (api, worker, web)	main merge `46f2322` (PR #58), tag `release-20261028-schemav2-p5-web`; migration `20261028140000_reviews_customer_notifications` applied (0 failed); health/ready OK, read-only smoke 10/10; `/customer/notifications` answers 401 (live); `/app` not served (VITE_MARKETPLACE unset, default bundle has no marketplace code); row counts unchanged (16 shops, 12 users, 27 orders); rollback images `printout-{api,web}:rollback-pre-p5-20261028`; pre-deploy backup `printout-20261028T115103Z` copied off-server (laptop) with matching sha256.

Repository state

Step	Status	Evidence
Docs PR #45	MERGED	`62d60b0`
Skill PR #46	MERGED	`647d45a`
Decisions recorded APPROVED	IN_PROGRESS	branch `docs/schema-v2-approvals`
development/main sync (PR #47)	IN_PROGRESS	candidate tree identical to main

Phase 1 - Identity and multi-shop (DEPLOYED, flags off)

Requirement	Status	Evidence
Customer role, role grants, nullable email, customer profile, `GET /shops/mine`, customer sign-in (audience), onboarding (flag off)	DEPLOYED	PR #49, squash `2b17805`; 23 tests + full suite 58 files

Phase 2 - Discovery (DEPLOYED; haversine backend, PostGIS not enabled)

Requirement	Status	Evidence
Shop address, coordinates, verification columns; paper options; photos (migration `20261028110000`)	TESTED	disposable PG16 upgrade with seeded data; no drift
Nearby search (haversine default)	TESTED	`schema-v2-phase2.test.ts` 17 tests
PostGIS backend + optional GiST index + runbook	TESTED on disposable PostGIS 3.4.3	`schema-v2-postgis.test.ts` 7 tests; production NOT enabled, pre-flight not yet run
Admin verify/block with audit	TESTED	phase 2 tests
Owner shop profile, paper options, photos (private, magic-byte checked)	TESTED	phase 2 tests
Customer discovery APIs	TESTED	phase 2 tests
Contract	IMPLEMENTED	`PHASE2_CONTRACT.md`, `POSTGIS_RUNBOOK.md`

Phase 3 - Customer orders (DEPLOYED, customer sign-up flag off so unused)

Requirement	Status	Evidence
Customer uploads (existing pipeline, 50 MiB, hourly limit), quotes, orders (shared server-authoritative pricing), history, cancel; guest QR unchanged	MERGED	PR #51 squash `5184848`; 10 tests; full suite 61 files
30-minute retention untouched; no customer file download	MERGED	by design

Phase 4 - Lifecycle and payments (MERGED to development, not deployed; PR #52, squash `43dd97b`)

Requirement	Status	Evidence
REJECTED status behind `ORDER_REJECT_ENABLED` (default off), terminal handling everywhere	TESTED	`schema-v2-phase4.test.ts`
Cash/UPI tracking, UTR claim, duplicate UTR per shop, shop verification, concurrency	TESTED	17 tests
Admin-only manual refund records, append-only payment events (DB trigger)	TESTED	17 tests
Shop order list `/shops/{shopId}/orders`, status adapter	TESTED	17 tests
Contract	IMPLEMENTED	`PHASE4_CONTRACT.md`; full suite 62 files green

Phase 5 - Reviews and notifications (DEPLOYED; PR #53 squash `fe72655`)

Requirement	Status	Evidence
Reviews: one per order, eligibility, aggregate in the same transaction, listings, no edit/delete	TESTED	`schema-v2-phase5.test.ts` 15 tests
Customer notification inbox (outbox rows, read/read-all, retention)	TESTED	same
Customer + shop-owner push, token cleanup, failure isolation (fake sender)	TESTED	same
Shop-owner in-app inbox rows for payment submission / verification	NOT_STARTED (deferred to phase 6 with the web bell)	`PHASE5_CONTRACT.md`
Contract	IMPLEMENTED	`PHASE5_CONTRACT.md`; full suite 63 files green

Phase 6 - Integration

Requirement	Status	Evidence
Web customer Google sign-in (cookie + CSRF)	DEPLOYED	`POST /auth/customer/google/session`, 5 tests
Customer web screens (sign-in, nearby, shop, order, orders, UPI ref, cancel, review, notifications)	DEPLOYED but OFF	built only with `VITE_MARKETPLACE=1`; 14 tests; PR #57
OpenAPI for all new routes	MERGED when this PR lands	`openapi-schema-v2.yaml` validated (32 paths, 37 operations)
ER + sequence diagrams, architecture PDF, updated skill	MERGED when this PR lands	`13-final-er-and-sequence-diagrams.md`, `schema-v2-architecture.pdf`
Shop-owner / admin web screens for payments, verification, refunds, reviews	NOT_STARTED (API is complete and tested)	contracts in PHASE2/4/5 docs
Shop-owner in-app inbox rows for payment submission/verification	NOT_STARTED	deferred with the web bell
Android customer app	BLOCKED: source not in this repository; contract in OpenAPI + `10-android-integration-plan.md`	
PostGIS on production	BLOCKED/PENDING: pre-flight not run; haversine in use	`POSTGIS_RUNBOOK.md`
Off-server backup remote for the nightly job	BLOCKED: needs an owner-chosen destination and credentials	
Turning on customer sign-up / reject / marketplace flag	NOT_STARTED (owner decision)	

Blockers and notes

- Android source is not on the active branch: Android deliverable is the API contract and integration guide only.
- Production access (`kp-production`) not yet inspected; no production action has been taken.